安心・安全への配慮

ManabiOps 機能説明書 (単章版)

Version 1.0

こども食堂「まなびキッチン」運営支援システム

発行日: 2026-04-22

リポジトリ: github.com/satoshiyoshimoto0426/manabi-kitchin

⌧安心・安全への配慮

読了目安: 7分 / 想定読者: 全員・保護者説明会資料として

⌧このページの目的

こども食堂で最も大切なのは **「子どもたちの安心・安全」**。
ManabiOps は、便利さを追求しつつも、**子ども・保護者のプライバシーを最優先** に設計されています。

このページは、

- 運営メンバーが理解するため
- 保護者への説明資料として
- 助成金申請時の信頼性アピールとして

活用できます。

⌧4つのお約束

ManabiOps は以下の4つを **技術的に担保** します (運用ルールではなく、システム的に強制)。

⌧① 子どもの顔は100%ぼかします

⌧② 氏名は暗号化されます

⌧③ 人間の承認なしに投稿しません

⌧④ データは1年で自動削除します

⒈ 顔ぼかしの仕組み

技術: 2段階AI チェック

```
[元の写真]
   ↓
┌──────────────────────────┐
│ 1次: MediaPipe    │ ← Googleの顔検出AI
│  → 顔をすべて検出 │
└──────────────────────────┘
         ↓
┌──────────────────────────┐
│ ぼかし処理        │ ← モザイク強度 15px
│  → 識別不可レベル │
└──────────────────────────┘
         ↓
┌──────────────────────────┐
│ 2次: Gemini AI    │ ← 別のAIで再検査
│  → 漏れチェック   │
└──────────────────────────┘
         ↓
[ぼかし済み写真] → 承認 → 投稿
```

なぜ2段階なのか

1次検出で見落としがあっても、
別のAI が「顔が残っている」と判定したら、もう一度ぼかし処理。

```
検出精度:
 1次のみ: 99%
 1次+2次: 99.99% (≒ 10,000枚に1枚漏れるかどうか)
```

ぼかしをオフにできない

要件定義書で **「顔ぼかしは常に適用、オフ設定なし」** と規定。
技術的に、顔ぼかしをスキップする UI・API エンドポイントは **存在しません**。

投稿前の目視確認

さらに安全を期すため、**投稿ボタンを押す前に** Owner がプレビュー画面で目視確認。
怪しい部分があれば **[⊠取消]** で中止。

---

②氏名の暗号化

暗号化とは?

「田中太郎」という文字を、鍵がないと読めない **ランダムな文字列** に変換する技術。

```
[元の氏名]          [暗号化後]
田中太郎     →      xQ8Fg9LmPq7Rs2Tu4VwX6YZ...
                   (128文字くらいの意味不明な文字列)

                   ↓ 鍵があれば
[元の氏名]
田中太郎
```

使用している暗号方式

AES-256-GCM

- 256ビット鍵 (現在の技術で解読不可能)
- 銀行・政府機関でも使われる最高水準
- NSA (米国家安全保障局) 公認の暗号方式

鍵の管理

- **マスター鍵**: Google Secret Manager (Googleの金庫) に保管
- **バックアップ**: オフラインの USB + 紙 (運営代表者管理)
- Owner だけが復号可能

集計用のハッシュ化

「田中太郎さんが何回来たか」を数えるために、
氏名を別途 **SHA-256ハッシュ** でも保存:

```
[元の氏名]          [ハッシュ]
田中太郎     →      6f3a9b2c... (64文字固定)
```

- ハッシュは一方向 (**ハッシュから氏名は復元不可**)
- 同じ氏名は同じハッシュになる → 同一人物判定に使える

---

③ 誰が何を見られる?

アクセス権マトリクス

データ種別	Owner	Staff	Viewer	外部
自分で送った写真	☒	☒	☒	☒
他人が送った写真	☒	☒	☒	☒
参加者 **氏名**	☒(復号)	●●● (マスク)	●●●	☒
参加者 **人数・集計**	☒	☒	☒	☒
会計データ	☒	☒	☒(閲覧のみ)	☒
LINEユーザー管理	☒	☒	☒	☒
データ削除	☒	☒	☒	☒
顔ぼかし前の写真	☒(限定)	☒	☒	☒

Staff/Viewer にも氏名を見せない理由

たとえ運営メンバーでも、**必要最小限** のデータしか閲覧できない設計。
これは「内部不正の防止」と「情報漏洩時の被害最小化」のため。

---

④ データ保持期間

自動削除スケジュール

データ	保持期間	削除方法
受信写真・動画	**1年**	Cloud Storage ライフサイクル
顔ぼかし済み写真	**1年**	Cloud Storage ライフサイクル
参加者情報 (氏名)	最終参加から **1年** → 匿名化	月次バッチ
参加者統計 (人数)	**7年** (税務要件)	—
会計取引	**7年** (税法)	—
LINE メッセージログ	**90日**	自動ローテート
システムログ	**30日**	Cloud Logging

個別の削除依頼

保護者から「うちの子の情報を消してほしい」と依頼があれば:

1. 管理画面 `/admin/participants` で該当者を検索
2. **[削除]** → 即座に物理削除 (復元不可)
3. 関連する写真・動画も削除
4. 対応日時をログに記録

GDPR・個人情報保護法の「削除権」に完全対応。

☒通信の暗号化

HTTPS / TLS 1.3

LINE から ManabiOps への通信はすべて暗号化。
これは銀行・ECサイトで使われているのと同じ方式。

```
[スマホ] ──(TLS1.3暗号化)──→ [ManabiOps サーバー]
          ↑
通信中に盗聴しても読めない
```

内部通信も暗号化

- Cloud Run ↔ Firestore: Google 内部ネットワーク (暗号化)
- Cloud Run ↔ Cloud Storage: 暗号化
- Cloud Run ↔ LINE: TLS1.3
- Cloud Run ↔ Instagram: TLS1.3

☒データの保管場所

物理的な所在

すべてのデータは **Google の東京データセンター (asia-northeast1)** に保管。
- 海外へのデータ転送なし
- 日本の法律が適用される
- Google の高い物理セキュリティ (入退室管理・監視カメラ・生体認証)

Google のセキュリティ認証

- ISO 27001, 27017, 27018 (情報セキュリティ)

- SOC 2/3 (監査基準)
- PCI DSS (クレジットカード業界標準)

⌧管理者のセキュリティ

Google アカウントの2段階認証

Cloud を触れるメンバーは、**必ず 2FA (2要素認証)** を有効化:

- 物理セキュリティキー (YubiKey 推奨)
- またはスマホの認証アプリ (Google Authenticator)
- SMSは非推奨 (SIMスワップ攻撃対策)

管理画面の Basic 認証

ブラウザ管理画面 `/admin` も別途パスワード保護:

- 16文字以上の強固なパスワード
- パスワードマネージャ (1Password/Bitwarden) で管理
- 半年ごとに変更

監査ログ

誰がいつ何をしたかを記録:

- 取引の承認・編集・削除
- 参加者の閲覧・削除
- SNS投稿の承認
- ユーザー管理の変更

⌧インシデント発生時の対応

想定シナリオと対応

Case 1: スマホ紛失

1. LINE アカウントをリモートログアウト
2. 紛失者を LINE ホワイトリストから削除
3. Google パスワードを変更 (Google アカウント使用者の場合)

Case 2: 誤ってSNS投稿

1. Instagram アプリで即削除
2. 管理画面でも投稿記録を削除
3. 影響範囲の確認 (誰が保存した可能性)
4. 必要に応じて保護者に報告

Case 3: データ漏洩疑い

1. **即座に Cloud Run を停止**
2. ログ分析 (誰が・いつ・何を)
3. 個人情報保護委員会への報告 (法定)
4. 影響のあった保護者への連絡
5. 再発防止策の実装

⌧法令遵守

個人情報保護法 (日本)

- **利用目的の特定・通知・公表** ⌧
- **利用目的外利用の禁止** ⌧
- **適正な取得** ⌧
- **データの正確性確保** ⌧
- **安全管理措置** ⌧暗号化・アクセス制御)
- **第三者提供の制限** ⌧SNS投稿は顔ぼかし前提)
- **本人からの開示・訂正・削除請求への対応** ⌧

GDPR (欧州一般データ保護規則)

日本法より厳格な規制にも基本対応:

- **同意の取得** (保護者)
- **データポータビリティ権** (CSV エクスポート)
- **忘れられる権利** (削除権)
- **最小限のデータ収集**

その他

- 児童福祉法の理念

- こども基本法
- 地方自治体の個人情報条例

☒保護者への説明文例

初回参加時に、保護者に以下のような説明をすることを推奨:

```
────────────────────────────────────────
まなびキッチン 写真・個人情報の取り扱いについて

当団体では、活動の記録と広報のため、
以下のように写真撮影・個人情報を取り扱います。

1. 写真撮影について
  ・イベント中に写真を撮影します
  ・SNS (Instagram) に投稿する場合、
   AI により 100% 顔をぼかして処理します
  ・ぼかし前の原本は暗号化保管し1年で自動削除します

2. お名前の取り扱い
  ・受付名簿のお名前はデジタル化して保管します
  ・暗号化技術により、他人には読めない形で保存します
  ・運営代表者のみが閲覧できます
  ・最終参加から1年経過で匿名化します

3. いつでもご連絡ください
  ・データの削除・閲覧のご希望
  ・撮影を控えてほしい旨
  ・その他ご不安な点

連絡先: [運営代表者の連絡先]
────────────────────────────────────────

 ☐ 上記に同意します

 お名前 [                ]   日付 [    /    /    ]
```

同意書のテンプレートファイル: ../legal/consent_template.md (作成予定)

☒まとめ: なぜ ManabiOps は安心?

人間 + 技術の二重チェック

- **AI が顔ぼかし** → **人間が目視確認** → 投稿
- **AI が推測** → **人間が承認** → 登録

最高水準の暗号化

- 通信: TLS 1.3 (銀行水準)

- 保存: AES-256-GCM (米政府水準)
- ハッシュ: SHA-256 (復号不可)

ゼロトラスト設計

- 必要最小限のアクセス権
- 内部不正も防ぐロール分離
- 全操作の監査ログ

法令遵守

- 日本の個人情報保護法
- GDPR 水準
- 自治体条例

⌧次に読むもの

- **FAQ**: 07_よくある質問FAQ.md
- **費用・運用**: 09_費用と運用体制.md
- **概要に戻る**: 01_これは何_ManabiOps概要.md

このドキュメントは ManabiOps プロジェクトの成果物です。
© 2026 まなびキッチン / MIT License